

- **Expediente N°: EXP202310943**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR RECONOCIMIENTO DE RESPONSABILIDAD Y PAGO VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 11 de abril de 2025, la Presidencia de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.** (en adelante, **AIRE NETWORKS**), mediante el acuerdo que se transcribe:

<<

Expediente N.º: EXP202310943

ACUERDO DE INICIO DE PROCEDIMIENTO SANCIONADOR

De las actuaciones practicadas por la Agencia Española de Protección de Datos y en base a los siguientes

HECHOS

PRIMERO: Con fecha 21 de julio de 2023 se interpuso reclamación ante la Agencia Española de Protección de Datos por una posible infracción imputable a **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.** con NIF **B53704599** (en adelante, **AIRE NETWORKS**).

Los hechos que se pusieron en conocimiento de esta autoridad eran:

Quien reclama expuso que, en fecha 27 de junio de 2023, se cortó su línea telefónica. El 28 de junio de 2023, se dirigió a la tienda de telefonía móvil *****EMPRESA.1**, donde distribuyen *****PRODUCTO.1** del operador de telecomunicaciones **AIRE NETWORKS**, sitio en el que le proporcionaron un duplicado de la tarjeta SIM.

El 29 de junio de 2023, el reclamante consulta su banca online y detecta las siguientes transacciones bancarias no autorizadas:

- Dos transferencias de *****CANTIDAD.1** euros el 28 de junio de 2023 a una cuenta bancaria española.
- Una transferencia de *****CANTIDAD.2** euros el 28 de junio de 2023 a una cuenta bancaria lituana.
- Una transferencia de *****CANTIDAD.2** euros el 28 de junio de 2023 a una cuenta bancaria española.

En fecha 29 de junio de 2023 formuló denuncia policial, y en fecha 3 de julio de 2023 presentó reclamación al banco *****BANCO.1**. Posteriormente, el reclamante afirma que detectó unos correos electrónicos que indicaban un cambio de dispositivo asociado a la banca online y cambio en la clave digital.

Junto al escrito, se aportó:

- Copia del correo electrónico enviado por quien reclama a *****EMAIL.1** con fecha 10 de julio de 2023, con el siguiente contenido: *“El pasado 27 de junio de 2023 me quedé sin teléfono, no podía hacer llamadas ni tenía conexión a internet. Seguidamente me dirigí al agente comercial *****EMPRESA.1**. La empresa comercializadora, después de consultarlo con ustedes via telefónica, siguieron sus instrucciones y me cambiaron mi tarjeta SIM. Por un lado, solicito saber en qué momento me quedé sin teléfono y el porqué. Mi comercial me informa que parece ser que ustedes tuvieron algún problema de seguridad y de manipulación de mi tarjeta SIM. A consecuencia de esto me han sustraído *****CANTIDAD.3** euros del banco mediante transferencias bancarias no autorizadas por mí. Indudablemente pensamos que se ha suplantado mi identidad tras su fallo de seguridad. Una vez consultado con la CNMC se me aconseja que hable primero con ustedes para solucionar este tema antes de pasar el caso a la misma CNMC. Paralelamente, mi comercial me informa que por protección de datos ustedes tendrían que haberse puesto en contacto conmigo para informarme del problema de seguridad que han tenido y sobre todo cuando los datos puestos en riesgo han sido datos de alta sensibilidad como son los datos bancarios. (...)”* (sic)
- Copia del correo electrónico enviado por *****EMAIL.1** a quien reclama con fecha 11 de julio de 2023, con el siguiente contenido: *“Buenas tardes **A.A.A.**, Como hemos trasladado vía telefónica, estamos completamente dispuestos e interesados en colaborar con Vd. y en la resolución de la incidencia. Por ello rogamos nos envíe copia de la denuncia presentada para tener toda la información posible y velar siempre por su interés.”* (sic)
- Copia del correo electrónico enviado por quien reclama a *****EMAIL.1** con fecha 11 de julio de 2023, con el siguiente contenido: *“Adjuntamos la denuncia que pusimos en cuanto detectamos las transferencias no autorizadas por el titular. Como pueden observar, los movimientos bancarios se realizaron cuando el teléfono falló. La denuncia es un documento vivo y está abierta a añadir información y pruebas relevantes al caso.”*
- Copia del correo electrónico enviado por *****EMAIL.1** a quien reclama con fecha 12 de julio de 2023, con el siguiente contenido: *“Trasladamos el documento a nuestro departamento jurídico para que realicen las gestiones necesarias para resolver la incidencia, le informaremos a la mayor brevedad posible.”*
- Copia del correo electrónico enviado por *****EMAIL.2** a quien reclama con fecha 11 de julio de 2023, con el siguiente contenido: *“A efectos de aclaración, desde Aire Networks del Mediterráneo, S.L.U. ofrecemos su servicio de telefonía*

móvil que usted contrató a través uno de nuestros agentes comercializadores de telefonía móvil, en su caso *****EMPRESA.1**". Disponemos de una plataforma online con funciones de Oficina Virtual (OV). Dicha extranet es la plataforma que Aire Networks pone a disposición de sus agentes comercializadores y empleados para la gestión administrativa de los servicios de telecomunicaciones de sus clientes finales, dicha plataforma permite administrar diferentes trámites relacionados con el servicio de telefonía como puede ser dar de alta o baja de servicios, consulta de consumos, duplicado de tarjetas SIM, facturación, etc. El pasado miércoles, 28 de junio *****EMPRESA.1** ponen en nuestro conociendo que el titular de la línea *****TELÉFONO.1** se encuentra sin servicio y que ha revisado la línea en la Oficina Virtual (extranet de Aire Networks) ve que se ha solicitado un duplicado de SIM en modalidad eSIM sobre la misma y que él alega no haber realizado. Ante lo que podría ser la comisión de un posible fraude procedimos a bloquear dicha eSIM y analizar lo sucedido de este análisis se deprenen los registros que les detallamos a continuación: LOG de acceso a la Oficina Virtual (extranet de Aire Networks) realizado por el usuario *****NIF.1**" el cual pertenece a *****EMPRESA.1**" realizado un minuto antes de la solicitud de duplicado (...). Desde Aire Networks, procedimos a denunciar los hechos ante la fiscalía como parte afectada, por este motivo **A.A.A.**, le pedimos también nos mantenga informados del estado de su reclamación ante su entidad bancaria en la que ha solicitado el retroceso de las transferencias ya que esta información nos es de gran ayuda a la hora de valorar el perjuicio causado y así poder aportar en nuestra denuncia la mayor información ante la fiscalía para la investigación del delito." (sic)

- Copia de la cartilla del banco *****BANCO.1** donde figuran como titulares el reclamante y que recoge cuatro transferencias denominadas "TRANSFERENCIA A **B.B.B.**", efectivas con fecha de 28 de junio de 2023, por un total de *****CANTIDAD.3** euros.
- Copia de las siguientes transferencias emitidas por el banco *****BANCO.1** y donde figura como ordenante el reclamante y como beneficiario "B.B.B.", con fecha de emisión emitidas el 27 de junio de 2023:
 - Transferencia a la cuenta *****CUENTA.1** del banco *****BANCO.2** por una cuantía de *****CANTIDAD.4** euros.
 - Transferencia a la cuenta *****CUENTA.2** del banco *****BANCO.3** por una cuantía de *****CANTIDAD.4** euros.
 - Transferencia a la cuenta *****CUENTA.2** del banco *****BANCO.3** por una cuantía de *****CANTIDAD.5** euros.
 - Transferencia a la cuenta *****CUENTA.2** del banco *****BANCO.3** por una cuantía de *****CANTIDAD.5** euros.
- Copia de denuncia policial formulada el 29 de junio de 2023 donde el reclamante declara que no ha realizado cuatro transferencias desde su cuenta con número *****CUENTA.3** en la entidad *****BANCO.1** por valor de *****CANTIDAD.3** euros ni ha autorizado a nadie a realizarlas, que no ha compartido sus contraseñas con nadie, así como que se ha dirigido al banco

para aclarar los hechos y le han informado que alguien ha accedido a su aplicación y ha realizado las transferencias.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), se dio traslado de dicha reclamación a AIRE NETWORKS, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

Con fecha 5 de septiembre de 2023 se recibe en esta Agencia escrito de respuesta de AIRE NETWORKS:

*“(…) Queremos informarle que la reclamación presentada por A.A.A. que origina esta solicitud de información previa está relacionada con la brecha de seguridad que comunicamos a la Agencia Española de Protección de Datos el día 27/06/2023 a las 19:23:07 con número de registro *****REGISTRO.1**, comunicación que fue ampliada posteriormente en tiempo y forma sobre los hechos, el estado de la brecha, medidas adoptadas, así como sus consecuencias y efectos a nivel de seguridad.*

*Esta brecha de seguridad se produjo como consecuencia de la filtración de los usuarios y contraseñas de 4 de nuestros agentes comercializadores (Encargados de tratamiento) entre ellos el mencionado por **A.A.A.** en su escrito a ustedes, *****EMPRESA.1 (N.I.F: ***NIF.1)** y uno de nuestros empleados. Como resultado de esta brecha se produjo el acceso a sus Oficinas Virtuales (extranet) (en adelante OV) por parte de personas no autorizadas a través de un medio ilícito de intrusión informática e interceptación de transmisiones de datos informáticos. A efectos de aclaración, para su mejor entendimiento, la OV (extranet) es la plataforma que Aire Networks, como prestadora de servicio de telecomunicaciones, pone a disposición de sus Agentes Comercializadores (entre ellos *****EMPRESA.1.**) para la gestión administrativa (contratación, facturación, portabilidades, bajas, duplicados de eSIM, etc.) de los servicios ofrecidos a los clientes finales.*

*Nota: El contrato de encargo de tratamiento por cuenta de terceros (art. 28 RGPD) “Contrato de tratamiento de datos por parte de *****EMPRESA.1** y por cuenta de Aire Networks del Mediterráneo S.L.U.”, suscrito por *****EMPRESA.1** (Agente Comercializador) se adjuntó en la comunicación de la brecha (con nº de registro *****REGISTRO.1**), no obstante, adjuntamos nuevamente en esta contestación extractos de dicho contrato en el cual se aprecian las instrucciones necesarias para evitar brechas de seguridad, el deber del Agente Comercializador de verificar la identidad de los clientes para realizar trámites; y el deber del Agente Comercializador de adoptar normas y medidas de seguridad sobre guarda y custodia que garanticen la seguridad de los datos y eviten su acceso no autorizado. Podrá ver dichos extractos del referido contrato en las páginas siguientes.”*

En la cláusula Novena, apartado 9.6, de dicho contrato, donde *****EMPRESA.1** es "EL OPERADOR", se indica lo siguiente: *"En todo caso el OPERADOR cumplirá con la normativa de aplicación a la protección de datos de carácter personal, adaptando las medidas técnicas y organizativas que garanticen la seguridad de los datos, su conservación y eviten su alteración, pérdida o acceso no autorizado."*

En la cláusula Decimotercera, "CONFIDENCIALIDAD Y PROTECCIÓN DE DATOS", el apartado 13.1 señala:

"El OPERADOR y todo su personal se obliga a:

- a) *Utilizar los datos personales objeto del tratamiento, o los que recoja para su inclusión, sólo para la finalidad objeto de este encargo. En ningún caso podrá utilizar los datos para fines propios. AIRE NETWORKS será responsable del tratamiento de los datos de los usuarios finales a los que preste servicios en lo que se refiera a la prestación de tales servicios, debiendo tratar los mismos conforme a lo establecido en la legislación vigente en materia de protección de datos, sin perjuicio de que el OPERADOR pueda ser así mismo responsable del tratamiento de dichos datos de los usuarios finales para aquellos servicios que el OPERADOR preste a estos, a cuyos efectos, se informará de dicha circunstancia a los usuarios finales en el momento de recogida de los datos a los efectos de que consientan el tratamiento por parte de ambas compañías.*
- b) *Tratar los datos de acuerdo con las instrucciones de AIRE NETWORKS. Si el OPERADOR considera que alguna de las instrucciones infringe el RGPD o cualquiera otra disposición en materia de protección de datos de la Unión o de los Estados miembros, el OPERADOR informará inmediatamente a AIRE NETWORKS (...).*
- d) *No comunicar los datos a terceras personas, salvo que cuente con la autorización expresa de AIRE NETWORKS, en los supuestos legalmente admisibles. EL OPERADOR puede comunicar los datos a otros encargados del tratamiento del mismo responsable, de acuerdo con las instrucciones de AIRE NETWORKS. En este caso, AIRE NETWORKS identificará, de forma previa y por escrito, la entidad a la que se deben comunicar los datos, los datos a comunicar y las medidas de seguridad a aplicar para proceder a la comunicación (...).*
- g) *Garantizar que las personas autorizadas para tratar datos personales se comprometan, de forma expresa y por escrito, a respetar la confidencialidad y*

cumplir las medidas de seguridad correspondientes, de las que hay que informarles convenientemente.

- h) Mantener a disposición de AIRE NETWORKS la documentación acreditativa del cumplimiento de la obligación establecida en el apartado anterior.*
- i) Garantizar la formación necesaria en materia de protección de datos personales de las personas autorizadas para tratar datos personales.”*

El escrito de AIRE NETWORKS recibido con fecha 5 de septiembre de 2023, continúa señalando lo siguiente:

*“De conformidad a lo informado en nuestra comunicación a esta Agencia, se realizó por nuestra parte una amplia investigación interna para la averiguación de los hechos y, pese a no haberse podido identificar el origen/causa de la filtración de credenciales (seguimos investigando de forma adicional a las investigaciones que ya ha iniciado la Fiscalía del área de *****LOCALIDAD.1** que dispone de más medios para identificar este origen), se determinó que aun cuando se habían adoptado proactivamente antes del incidente medidas técnicas y organizativas necesarias y adecuadas para garantizar la seguridad de los datos personales, los accesos no autorizados en las Oficinas Virtuales afectadas (OV) (extranet) no se produjeron debido a una falta o deficiente aplicación de las medidas preventivas implementadas o por un aprovechamiento de vulnerabilidades técnicas de nuestra infraestructura que pudiera ser usada para un ataque directo, sino mediante la obtención de las credenciales de acceso legítimas, debidamente cifradas, por uno o varios delincuentes con elevados conocimientos informáticos a través de medios o procedimientos técnicos digitales de difícil detección y trazabilidad, que permitieron, de forma excepcional, que se produjese la mencionada incidencia. Consecuencia de ello es que, en ningún caso, se ha producido el duplicado de la eSIM de **A.A.A.** debido a un error, inobservancia o falta de diligencia en la verificación de la identidad del titular legítimo por parte de nuestro personal, sino por los motivos anteriormente expuestos y evidenciados en la comunicación.*

*Por último, nos gustaría manifestar que, como ya se ha indicado anteriormente, como parte también afectada, desde Aire Networks se interpuso denuncia ante la Fiscalía de *****LOCALIDAD.1 (...)**, habiéndonos puesto a disposición de las Fuerzas y Cuerpos de Seguridad del Estado que han abierto la correspondiente investigación, así como lo hacemos con ustedes, para ofrecer la máxima colaboración para la averiguación y esclarecimiento de estos hechos que ha provocado este delito cibernético.”*

TERCERO: Con fecha 13 de octubre de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VIII, de la LOPDGDD.

Como consecuencia de las actuaciones realizadas, se ha tenido conocimiento de los siguientes extremos:

En fecha 17 de abril de 2024, AIRE NETWORKS presentó un escrito de respuesta a requerimiento de esta Agencia, del que se extrae la siguiente información:

*Personas afectadas *****CANTIDAD.6** con datos de identificación (nombre, apellidos, nacionalidad, fecha de nacimiento y documento de identidad) y datos de contacto (correo electrónico, teléfono, dirección postal) y otros *****CANTIDAD.7** también con datos de domiciliación de cobro.*

******CANTIDAD.7** posibles afectados en los que pudieron ser visualizados datos financieros (domiciliación del cobro).*

*Indican acceso no autorizado realizado a través de las credenciales de acceso de los agentes comercializadores por parte de ciberdelincuentes con lo cual *****CANTIDAD.8** clientes han sido afectados gracias a la comunicación de la incidencia por parte de estos, habiéndole sustraído dinero de sus cuentas bancarias debido al duplicado eSIM de manera ilícita.*

*Indican que en fecha de respuesta a este escrito solo tienen conocimiento de la utilización de *****CANTIDAD.8** eSIM, obtenidas ilícitamente por los ciberdelincuentes mediante las cuales pudieron recibir mensajes SMS destinados a los *****CANTIDAD.8** titulares de las *****CANTIDAD.8** líneas móviles afectados como parte del proceso de vencimiento de las medidas de seguridad aplicadas por los sistemas de pago de la entidad bancaria (*****BANCO.1**).*

*En fecha 12 de julio de 2024 notifican a los afectados por SMS con el siguiente texto: "INFO: le informamos que tiene un comunicado referente a su línea móvil. Acceda a URL *****URL.1** (código: XXXXXX)". Se adjunta captura de pantalla de la web con los contenidos de varios comunicados.*

*De los *****CANTIDAD.6** clientes que se vieron afectados por la brecha de seguridad originada por el acceso no autorizado a la Oficina Virtual del encargado del tratamiento (4 Agentes Comercializadores y 1 empleado) únicamente tenemos constancia de que sus datos personales hayan sido utilizados por terceros en los 2 casos expuestos (siendo uno de ellos A.A.A. con NIF *****NIF.3** cuyo nombre consta en los registros de esta Agencia por haberse constituido como reclamante).*

Indican que no tienen conocimiento de que los datos personales obtenidos a causa de la brecha hayan sido publicados en internet ni que los mismos hayan sido indexados por los buscadores, tras las acciones de investigación realizadas por su equipo de Ciberseguridad.

Respecto del motivo por el cual las medidas de seguridad implantadas no han impedido el incidente de seguridad, indican lo siguiente:

"Las medidas de seguridad implantadas no han impedido el incidente de seguridad debido a 2 causas fundamentales:

- 1. La falta de diligencia en la custodia de las credenciales de acceso al sistema *****SISTEMA.1** (extranet) por parte de los agentes comercializadores (4) y al sistema *****SISTEMA.1** por parte de uno de nuestros empleados (**C.C.C.** cuyo contrato de confidencialidad ya fue aportado a la AEPD).*
- 2. Para uno de los casos, los ciberdelincuentes contaban con el control de la cuenta de correo (*****EMAIL.2**) donde se recibió el código del factor de autenticación. La obtención ilícita de dichas credenciales es lo que permitió que un ciberdelincuente pudiera actuar como si fuera un agente comercializador."*

AIRE NETWORKS adjunta como Anexo I a su contestación de 17 de abril de 2024 la evolución cronológica de los hechos:

24 y 25 de junio:

Se observan intentos de acceso válidos y no válidos a nombre del agente *****AGENTE.1** a la intranet de AIRE NETWORKS los días 24 y 25 de junio desde una dirección IP registrada en *****PAÍS.1**.

“El agente comercializador nos comunica mediante la apertura de un ticket que varias (14) líneas móviles han quedado sin servicio y que consultando la ficha de las mismas ve que se han realizado duplicados de tarjeta eSIM los cuales él no ha solicitado. Se le facilita los registros de accesos con sus credenciales en los que se realizaron dichas solicitudes y el agente comercializador nos comunica que él no ha procedido a realizar dichos accesos.”

“Medidas de seguridad adicionales de refuerzo aplicadas:

- Las eSIM duplicadas anteriormente mencionadas son bloqueadas para evitar un posible uso ilícito.
- Se indica al agente comercializador que realice nuevos duplicados de SIM para restablecer el servicio a las líneas afectadas.
- La(s) IP(s) desde las que se han realizado los accesos no autorizados son bloqueadas a través de cortafuegos para que no puedan acceder a ninguno de nuestros sistemas.
- Se fuerza el cambio de contraseña de acceso a *****SISTEMA.1** (extranet de Aire Networks) a todos los usuarios de dicho agente comercializador.”

26 de junio:

El día 26 de junio se observan 2 intentos de acceso válidos a nombre del agente *****AGENTE.2** a la intranet de AIRE NETWORKS desde la misma dirección IP indicada en el caso anterior la cual está registrada en *****PAÍS.1**.

“El agente comercializador nos comunica mediante la apertura de un ticket que varias (7) líneas móviles han quedado sin servicio y que consultando la ficha de las mismas ve que se han realizado duplicados de tarjeta eSIM los cuales él no ha solicitado. Se le facilita los registros de accesos con sus credenciales en los que se realizaron dichas solicitudes y el agente comercializador nos comunica que él no ha procedido a realizar dichos accesos.”

“Medidas de seguridad adicionales de refuerzo aplicadas:

- Las eSIM duplicadas anteriormente mencionadas son bloqueadas para evitar un posible uso ilícito.
- Se indica al agente comercializador que realice nuevos duplicados de SIM para restablecer el servicio a las líneas afectadas.
- La(s) IP(s) desde las que se han realizado los accesos no autorizados son bloqueadas a través de cortafuegos para que no puedan acceder a ninguno de nuestros sistemas.
- Se fuerza el cambio de contraseña de acceso a *****SISTEMA.1** (extranet de Aire Networks) a todos los usuarios de todos los agentes comercializadores.
- Se bloquea el acceso a *****SISTEMA.1** (extranet de Aire Networks) a todas las IPs que NO estén geolocalizadas en España (Intento: “acceso bloqueado desde IP no válida”).”

26 al 28 de junio:

Del día 26 al 28 de junio se observan varios accesos válidos a nombre del agente *****EMPRESA.1** a la intranet de AIRE NETWORKS desde diferentes direcciones IP ubicadas en diferentes regiones de España.

Acciones realizadas durante dichos accesos:

Duplicado de eSIM (2) realizados con las credenciales de acceso del agente comercializador *****EMPRESA.1** con CIF *****NIF.1** y con una dirección de correo (*****EMAIL.3**) que según el reclamante no es la suya y la cual fue usada en los diferentes accesos a nombre de los otros agentes indicados anteriormente en este informe.

“El agente comercializador nos comunica mediante la apertura de un ticket que varias (2) líneas móviles han quedado sin servicio y que consultando la ficha de las mismas ve que se han realizado duplicados de tarjeta eSIM los cuales él no ha solicitado. Se le facilita los registros de accesos con sus credenciales en los que se realizaron dichas solicitudes y el agente comercializador nos comunica que él no ha procedido a realizar dichos accesos.”

“Medidas de seguridad adicionales de refuerzo aplicadas:

- *Las eSIM duplicadas anteriormente mencionadas son bloqueadas para evitar un posible uso ilícito.*
- *Se procede dar nuevamente servicio a la SIM anterior para que el titular esté el menos tiempo posible sin servicio.*
- *La(s) IP(s) desde las que se han realizado los accesos no autorizados son bloqueadas a través de cortafuegos para que no puedan acceder a ninguno de nuestros sistemas.*
- *Se sobrescriben todas las contraseñas de todos los usuarios por contraseñas no validadas y se fuerza nuevamente el cambio de contraseña de todos los usuarios de todos los agentes comercializadores.”*

27 y 28 de junio:

Los días 27 y 28 de junio se registran varios accesos del empleado **C.C.C.** con DNI *****NIF.2**.

Acciones realizadas durante dichos accesos: Duplicado de eSIM (13) realizados con las credenciales de acceso de dicho empleado.

“Como nueva medida de seguridad, los compañeros del departamento de soporte reciben una alarma instantánea por cada una de las eSIM que ha creado el trabajador (C.C.C.) y activan los protocolos internos para investigar lo sucedido.”

“Medidas de seguridad adicionales de refuerzo aplicadas:

- *Se deshabilita el acceso a *****SISTEMA.1** de dicho trabajador, que en el momento en que suceden los hechos se encuentra de baja (I.T.).*
- *Las eSIM duplicadas anteriormente mencionadas son bloqueadas para evitar un posible uso ilícito.*
- *Se procede dar nuevamente servicio a la SIM anterior para que el titular esté el menos tiempo posible sin servicio.*

- La(s) IP(s) desde las que se han realizado los accesos no autorizados son bloqueadas a través de cortafuegos para que no puedan acceder a ninguno de nuestros sistemas.
- Se sobrescriben todas las contraseñas de todos los empleados por contraseñas no validadas y se fuerza el cambio de contraseña de todos los empleados de la compañía."

29 de junio de 2023:

"Medidas de seguridad adicionales de refuerzo aplicadas:

- Se limita el acceso a *****SISTEMA.1** Trabajadores mediante cortafuegos para que solo pueda ser accedido desde las IPs de nuestras oficinas."

30 de junio:

El 30 de junio se registran nuevos intentos de acceso a OFICINA VIRTUAL y a EMPLEADOS por parte del trabajador **C.C.C.** los cuales resultaron frustrados (según el reclamado) por las medidas de seguridad implementadas.

"Medidas de seguridad adicionales de refuerzo aplicadas:

(...)

6 de julio:

"Medidas de seguridad adicionales de refuerzo aplicadas:

(...)

7 de julio:

"En este punto, y ante la evidencia de la comisión de un delito cibernético, Aire Networks decide interponer una denuncia ante la Fiscalía de *****LOCALIDAD.1** para que se procediese al inicio de las averiguaciones penales correspondientes contra quien o quienes hubieran participado de los hechos expuestos constitutivos de delito de intrusión informática e interceptación de transmisiones de datos informáticos (197 bis CP) y delito de estafa con medios electrónicos. (248.2 CP). (...)"

8 de julio:

Se observa un acceso validado a la oficina virtual en nombre de *****EMPRESA.2** con CIF *****NIF.4**.

Se solicitaron los duplicados de (...) eSIM con las credenciales del agente anteriormente indicado.

Se observan otros 5 intentos de acceso frustrados.

En la página 38/79 se presenta un informe de ANÁLISIS Y GESTIÓN DE RIESGOS (en la que se recogen todas las amenazas que pueden afectar a la plataforma *****SISTEMA.1**, entre ellos "Accesos no autorizados") donde, según el control de cambios (pág 40/79), las últimas modificaciones con respecto a seguridad "Actualización a ENS Alta" data del 27 de abril de 2022 y "Actualización de los objetivos de seguridad" data del 01 de junio de 2002, dicho "Análisis y Gestión de Riesgo" sigue el estándar internacional ISO/IEC 27001 según el reclamado.

Esta norma especifica los requisitos necesarios para establecer, implantar, mantener y mejorar un sistema de gestión de la seguridad de la información según el Ciclo de Deming, o ciclo PHVA (acrónimo de Planificar, Hacer, Verificar, Actuar).

En este análisis de riesgos el reclamado indica:

“Objeto

(...)

Las conclusiones del reclamado a este análisis de riesgos es la siguiente:

“Una vez mantenidas entrevistas con el personal responsable, analizada la documentación aportada y realizado el trabajo de campo para la elaboración del análisis de riesgos, se ha llegado a la conclusión de que el nivel de riesgo actual existente en el alcance del SGSI se encuentra en general en un nivel Medio-Bajo.

Actualmente existe una base implantada de controles con un nivel de madurez L2-L3, que alcanza, al menos, un nivel L4 en aquellos activos que se encuentran relacionados con los servicios del alcance certificado de ENS Alta, que consiguen reducir considerablemente el riesgo inherente que potencialmente existe sobre los activos. Estos controles o salvaguardas están incluidos dentro del área de seguridad, medidas de contingencia y las medidas de respaldo. (...).

Como resumen de lo anteriormente expuesto, se puede concluir que el grado de implantación del SGSI, para el alcance definido, es adecuado y que será necesario realizar una gestión del riesgo en aquellas áreas donde se supere el riesgo aceptado por Dirección. El sistema de gestión va madurando, si bien es cierto que en algunas ocasiones para aumentar el nivel de madurez en ciertas áreas el esfuerzo que esto supone no compensa para el grado de disminución real del riesgo.”

“... Resultados obtenidos en el Análisis de Riesgos de Seguridad de la Información

En base a todo lo expuesto hasta el momento y tras calcular el Riesgo Potencial (Inherente), Riesgo Residual (Real) y Riesgo Residual (Futuro) se han mostrado los resultados reflejados en el documento RG-S-03 Análisis y Gestión de Riesgos (2023) ante la Dirección en la presentación del presente informe.”

En la página 60/79 se afirma:

“A continuación, se presentan los proyectos para llevar a cabo la implantación de controles y salvaguardas para la minimización del riesgo de seguridad sobre los activos tratados:

(...)

El reclamado presenta un pequeño extracto del análisis de riesgos para el ejercicio 2023 (pág. 78/79).

QUINTO: De acuerdo con el informe recogido de la herramienta AXESOR el día 3 de febrero de 2025, la entidad AIRE NETWORKS es una empresa constituida en el año 2002, y con un volumen de negocios de 107.746.223 euros en el año 2023.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

II

Procedimiento

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos”*.

De acuerdo con el artículo 64 de la LOPDGDD, y teniendo en cuenta las características de las presuntas infracciones cometidas, se inicia un procedimiento sancionador.

El procedimiento tendrá una duración máxima de doce meses a contar desde la fecha del acuerdo de inicio. Transcurrido ese plazo se producirá su caducidad y, en consecuencia, el archivo de actuaciones, de conformidad con lo establecido en el artículo 64 de la LOPDGDD.

Si en el plazo estipulado no efectuara alegaciones a este acuerdo de inicio, el mismo podrá ser considerado propuesta de resolución, según lo establecido en el artículo 64.2.f) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP).

III

Cuestiones previas

El artículo 4.1) del RGPD, define «dato personal» como: *“toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o*

indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona”.

El artículo 4.2) del RGPD, define «tratamiento» como: *“cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción.”*

El artículo 4.7) del RGPD, define al «responsable del tratamiento» o «responsable» como: *“la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros”.* A su vez el artículo 4.8) del RGPD determina al «encargado del tratamiento» o «encargado» como *“la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento”.*

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que AIRE NETWORKS realiza, entre otros tratamientos, la recogida y conservación de datos personales de personas físicas, entre otros: nombre, apellidos, nacionalidad, fecha de nacimiento, documento de identidad, correo electrónico, teléfono y dirección postal.

AIRE NETWORKS realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD. En este sentido, la cláusula decimotercera del “*Contrato de tratamiento de datos por parte de ***EMPRESA.1 y por cuenta de Aire Networks del Mediterráneo S.L.U.*”, indica lo siguiente: *“(…) AIRENETWORKS será responsable del tratamiento de los datos de los usuarios finales a los que preste servicios en lo que se refiera a la prestación de tales servicios, debiendo tratar los mismos conforme a lo establecido en la legislación vigente en materia de protección de datos (…).”*

Por otro lado, ***EMPRESA.1, calificada como *agente comercializador*, tendría la consideración de encargado de tratamiento por cuenta de AIRE NETWORKS.

IV

Obligación incumplida. Integridad y confidencialidad

La letra f) del artículo 5.1 del RGPD propugna:

*“1. Los datos personales serán:
(…)*

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»)."

El citado principio de integridad y confidencialidad obliga a los responsables del tratamiento a garantizar que los datos personales sean tratados de manera segura, evitando accesos no autorizados, usos indebidos o divulgación a terceros no autorizados. Esto incluye implementar medidas técnicas y organizativas adecuadas para proteger los datos frente a posibles brechas de datos personales, tanto externas como internas. Estas medidas deben ser apropiadas a los riesgos que puedan derivarse del tratamiento, y deben ser revisadas y actualizadas periódicamente para garantizar su eficacia.

En este sentido, los responsables han de garantizar la integridad y confidencialidad de los datos personales objeto de tratamiento a través de medidas técnicas y organizativas de todo tipo. El cumplimiento de dicho precepto se constataría, por lo tanto, mediante i) la adopción y cumplimiento de medidas técnicas y organizativas de todo tipo cuyo objetivo sea garantizar la confidencialidad y la integridad de los datos personales objeto de tratamiento ii) la ausencia de situaciones de pérdida de confidencialidad o integridad de los datos personales tratados. Su incumplimiento, por el contrario, devendría de la ausencia de medidas o incumplimiento de las adoptadas y de una pérdida de confidencialidad de los datos objeto de tratamiento.

En este caso, tal y como reconoce AIRE NETWORKS en su escrito de fecha 05 de septiembre de 2023, la vulneración del principio de confidencialidad se produce debido a una brecha de seguridad derivada de la filtración de credenciales de acceso a una extranet corporativa denominada *****SISTEMA.1**, lo que habría permitido a los atacantes realizar gestiones indebidas, entre ellas, la emisión de un duplicado de tarjeta SIM que facilitó las posteriores sustracciones en las cuentas bancarias de los afectados a través de los sistemas de banca online. La filtración de credenciales incluyó cuentas de empleados y de un proveedor externo, lo que evidenciaría la existencia de deficiencias en la gestión de la seguridad de los accesos al sistema. En esta brecha de datos personales estarían involucrados varios agentes comercializadores de AIRE NETWORKS; además de *****EMPRESA.1**, *****AGENTE.1**, *****AGENTE.2** y *****EMPRESA.2**. Todo ello, de acuerdo a la información suministrada en el marco de las actuaciones de investigación llevadas a cabo por esta AEPD. En un primer momento, AIRE NETWORKS vincula la brecha de datos personales a las siguientes circunstancias:

1. *"La falta de diligencia en la custodia de las credenciales de acceso al sistema *****SISTEMA.1** (extranet) por parte de los agentes comercializadores (4) y al sistema *****SISTEMA.1** por parte de uno de nuestros empleados (C.C.C. cuyo contrato de confidencialidad ya fue aportado a la AEPD).*

1. *Para uno de los casos, los ciberdelincuentes contaban con el control de la cuenta de correo (*****EMAIL.2**) donde se recibió el código del factor de autenticación. La obtención ilícita de dichas credenciales es lo que permitió que un ciberdelincuente pudiera actuar como si fuera un agente comercializador.”*

No obstante, puede afirmarse que, ni antes ni después de los ataques, las medidas parecen ser las adecuadas. Así, en el caso de una de las filtraciones- desde IP localizadas en *****PAÍS.1-**, como medida reactiva se bloquea el acceso a *****SISTEMA.1** (extranet de Aire Networks) a todas las IPs que no estén geolocalizadas en España (Intento: “*acceso bloqueado desde IP no válida*”). Es decir, esta medida básica de seguridad que impediría que se accediera desde IPs no situadas en España, toda vez que la actividad comercial y, por lo tanto, los agentes comercializadores de AIRE NETWORKS se encontrarían en nuestro país, no había sido adoptada previamente. Sin duda, esta carencia facilitó esta brecha de datos personales. De esta medida se informa respecto del ataque sufrido por *****AGENTE.1** (24/25 de junio), pero es que, al día siguiente, 26 de junio, *****AGENTE.2** sufrió también sendos accesos desde la misma IP localizada en *****PAÍS.1**. En este caso, se adoptó la siguiente medida: “*La(s) IP(s) desde las que se han realizado los accesos no autorizados son bloqueadas a través de cortafuegos para que no puedan acceder a ninguno de nuestros sistemas.*” Ello parecería evidenciar que la medida adoptada anteriormente de bloquear el acceso a IPs no localizadas en España no habrían causado efecto.

Por otro lado, el caso de *****EMPRESA.1**, y referido a la reclamación de la que trae causa el presente procedimiento, se informa que dos duplicados de eSIM fueron realizados con las credenciales de este agente comercializador y utilizando una dirección de correo- *****EMAIL.3-** que no se corresponde con la del reclamante. Este hecho denota que no existían medidas para comprobar la adecuación de la dirección de correo con la efectiva del cliente, de la que deberían disponer al tratarse de un duplicado de tarjeta, en este caso, una eSIM. Se da además la circunstancia que esta misma dirección de correo fue utilizada en diferentes accesos a nombre de otros agentes involucrados.

Otra circunstancia que denota una carencia de medidas que eviten la pérdida de confidencialidad de los datos objeto de tratamiento es que, en otro de los casos detectados, fueron utilizados las credenciales de un trabajador que se encontraba en el momento de los hechos en situación de baja laboral. Esta circunstancia, que debiera haber sido tomada en cuenta para, por ejemplo, el bloqueo temporal de las credenciales de dicho trabajador no fue detectada sino hasta con carácter posterior al ataque. Un ataque que podría haberse evitado, en este supuesto concreto si, como decimos, no hubiesen continuado siendo válidas las credenciales del trabajador mientras se encontraba de baja y, lógicamente, no podía utilizarlas.

Finalmente, con fecha 30 de junio y 6 de julio informan de la habilitación de una medida de relevancia como es el doble factor de autenticación (2FA) para el acceso a *****SISTEMA.1** por parte de todos los empleados de la compañía y para el acceso a *****SISTEMA.1** por parte de todos los agentes comercializadores. No obstante, en las actuaciones de investigación y al informar sobre el motivo por el que las medidas de

seguridad implantadas no habían evitado el incidente, AIRE NETWORKS indicaba que:

*“Para uno de los casos, los ciberdelincuentes contaban con el control de la cuenta de correo (*****EMAIL.2**) donde se recibió el código del factor de autenticación. La obtención ilícita de dichas credenciales es lo que permitió que un ciberdelincuente pudiera actuar como si fuera un agente comercializador.”*

Por lo tanto, no queda claro si la medida consistente en tener un 2FA para el acceso i) estaba implantada, pero no consiguió evitar el incidente; o ii) fue adoptada con posterioridad como afirma respecto de las actuaciones llevadas a cabo el 30 de junio y el 6 de julio.

En consecuencia, el procedimiento que la parte reclamada tenía establecido para tener acceso a los datos personales de sus clientes, en el que se aprecia una insuficiencia de medidas de seguridad adecuadas en sus sistemas, tal y como ha reconocido la parte reclamada, habría permitido que se produjera una brecha de datos personales con la pérdida de confidencialidad de las credenciales, lo que facilitó el acceso indebido a los datos personales de 40 personas, incluyendo a los dos titulares de las dos líneas móviles afectadas que tuvieron consecuencias en sus cuentas bancarias. Esto constituiría una vulneración del art. 5.1.f) del RGPD, quedando expuestos los datos personales a un acceso no autorizado con consecuencias perjudiciales para el reclamante y el resto de afectados.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a AIRE NETWORKS, por vulneración del artículo transcrito anteriormente.

V

Tipificación de la infracción del artículo 5.1.f) del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración de los artículos siguientes, que se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

“a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;”

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

"En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679."

VI

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;

f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;

g) las categorías de los datos de carácter personal afectados por la infracción;

h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;

i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;

j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y

k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de AIRE NETWORKS de 107.746.223 en 2023.

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2, letra a), del RGPD): La brecha de seguridad en AIRE NETWORKS derivada de la filtración de credenciales de acceso a la extranet corporativa,

denominada *****SISTEMA.1**, permitió a los atacantes acceder a los datos personales de 40 personas y realizar gestiones indebidas, entre ellas, la emisión de un duplicado de tarjeta SIM que facilitó las posteriores sustracciones en las cuentas bancarias de dos afectados a través de los sistemas de banca online el 27 de junio de 2023. Cabe señalar que la brecha afectó a otros interesados además del reclamante y que fue facilitada por la falta de adopción de medidas básicas como el bloqueo de accesos mediante IPs en el extranjero, el bloqueo temporal de las credenciales de acceso de los trabajadores en situación de baja laboral o la adecuada implantación del doble factor de autenticación para los accesos por parte de los trabajadores de la entidad o de los agentes comercializadores. Asimismo, es destacable que algunas de las medidas adoptadas no impidieron que, con posterioridad, hubiera accesos exitosos.

- Las categorías de los datos de carácter personal afectados por la infracción (artículo 83.2, letra g), del RGPD): A este respecto, cabe recordar que, según información suministrada por AIRE NETWORKS, la brecha afectó a: *“Personas afectadas *****CANTIDAD.6** con datos de identificación (nombre, apellidos, nacionalidad, fecha de nacimiento y documento de identidad) y datos de contacto (correo electrónico, teléfono, dirección postal) y otros *****CANTIDAD.7** también con datos de domiciliación de cobro.”* Recordemos que tanto el número de identificación como los datos de carácter financiero son considerados por el Comité Europeo de protección de Datos (CEPD) como datos personales que han de incluirse entre los referidos por el art. 83.2 g). Asimismo, el apartado 57 de las Directrices 04/2022, sobre el cálculo de las multas administrativas contempladas en el RGPD, señala lo siguiente:

“En cuanto al requisito de tener en cuenta las categorías de los datos personales afectados [artículo 83, apartado 2, letra g), del RGPD], el RGPD destaca claramente los tipos de datos que merecen una protección especial y, por tanto, una respuesta más estricta en lo que respecta a las multas. Esto se refiere, como mínimo, a los tipos de datos a que se refieren los artículos 9 y 10 del RGPD y a los datos fuera del ámbito de aplicación de estos artículos cuya difusión provoque daños y perjuicios inmediatos al interesado (por ejemplo, datos de localización, datos sobre comunicaciones privadas, números de identificación nacionales o (...)). En general, cuantas más de estas categorías de datos estén implicadas o más sensibles sean los datos, más peso podrá atribuir la autoridad de control a este factor.”

Asimismo, se consideran los siguientes factores de graduación en calidad de agravantes:

- La vinculación de la actividad del infractor con la realización de tratamientos de datos personales (artículo 76.2, letra b), de la LOPDGDD): La actividad de AIRE NETWORKS y, más en concreto, el tratamiento en el que se ha producido la brecha de confidencialidad, está intrínsecamente vinculada a la realización de tratamientos de datos personales, ya que su funcionamiento implica la recopilación, almacenamiento, gestión y transmisión de información de sus clientes. Así, para prestar el servicio de telefonía e internet, la reclamada debe tratar datos personales como nombre, dirección, número de teléfono, correo electrónico y datos bancarios de los clientes.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD, permite fijar inicialmente una sanción de multa administrativa de **100.000,00 euros**.

Por lo tanto, a tenor de lo anteriormente expuesto, por la Presidencia de la Agencia Española de Protección de Datos,
SE ACUERDA:

PRIMERO: INICIAR PROCEDIMIENTO SANCIONADOR a **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.**, con NIF **B53704599**, por la presunta infracción del Artículo 5.1.f) del RGPD, tipificada en el artículo 83.5 del RGPD.

SEGUNDO: NOMBRAR como instructora a **R.R.R.** y, como secretaria, a **S.S.S.**, indicando que podrán ser recusados, en su caso, conforme a lo establecido en los artículos 23 y 24 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

TERCERO: INCORPORAR al expediente, a efectos probatorios, la reclamación interpuesta por la parte reclamante y su documentación, así como, así como los documentos obtenidos y generados por la Subdirección General de Inspección de Datos en las actuaciones previas al inicio del presente procedimiento sancionador.

CUARTO: QUE a los efectos previstos en el art. 64.2 b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, la sanción que pudiera corresponder sería de multa administrativa de **100.000,00 euros**, sin perjuicio de lo que resulte de la instrucción.

QUINTO: NOTIFICAR el presente acuerdo a **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.**, con NIF **B53704599**, otorgándole un plazo de audiencia de diez días hábiles para que formule las alegaciones y presente las pruebas que considere convenientes. En su escrito de alegaciones deberá facilitar su NIF y el número de procedimiento que figura en el encabezamiento de este documento.

De conformidad con lo dispuesto en el artículo 85 de la LPACAP, podrá reconocer su responsabilidad dentro del plazo otorgado para la formulación de alegaciones al presente acuerdo de inicio; lo que llevará aparejada una reducción de un 20% de la sanción que proceda imponer en el presente procedimiento. Con la aplicación de esta reducción, la sanción quedaría establecida en **80.000,00 euros**, resolviéndose el procedimiento con la imposición de esta sanción.

Del mismo modo podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá la reducción de un 20% de su importe. Con la aplicación de esta reducción, la sanción quedaría establecida en **80.000,00 euros** y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

La reducción por el pago voluntario de la sanción es acumulable a la que corresponde aplicar por el reconocimiento de la responsabilidad, siempre que este reconocimiento de la responsabilidad se ponga de manifiesto dentro del plazo concedido para formular alegaciones a la apertura del procedimiento. El pago voluntario de la cantidad referida en el párrafo anterior podrá hacerse en cualquier momento anterior a la resolución. En este caso, **si procediera aplicar ambas reducciones, el importe de la sanción quedaría establecido en 60.000,00 euros.**

En todo caso, la efectividad de cualquiera de las dos reducciones mencionadas estará condicionada al desistimiento o renuncia expresos de cualquier acción o recurso en vía administrativa contra la sanción.

A estos efectos, en caso de acogerse a alguna de ellas, deberá remitir a la Subdirección General de Inspección de datos comunicación expresa indicando a cuál de las dos reducciones se acoge o si es a las dos.

En caso de que optara por proceder al pago voluntario de cualquiera de las cantidades señaladas anteriormente (**80.000,00 euros o 60.000,00 euros**), deberá hacerlo efectivo mediante su ingreso en la cuenta nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa de reducción del importe a la que se acoge. Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección.

Por último, se señala que conforme a lo establecido en el artículo 112.1 de la LPACAP, contra el presente acto no cabe recurso administrativo alguno.

1479-290125

Lorenzo Cotino Hueso
El Presidente de la Agencia Española de Protección de Datos

>>

SEGUNDO: En fecha 13 de mayo de 2025, **AIRE NETWORKS** ha procedido al pago de la sanción en la cuantía de **60.000,00 euros** haciendo uso de las dos reducciones previstas en el acuerdo de inicio transcrito anteriormente, lo que implica el reconocimiento de la responsabilidad en relación con los hechos a los que se refiere el acuerdo de inicio y su calificación jurídica.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP), bajo la rúbrica *"Terminación en los procedimientos sancionadores"* dispone lo siguiente:

"1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente."

III

Pago voluntario y reconocimiento de responsabilidad

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en el acuerdo de inicio notificado se informaba sobre la posibilidad de reconocer la responsabilidad y de realizar el pago voluntario de la sanción propuesta, lo que supondría dos reducciones acumulables de un 20% cada una. Con la aplicación de estas dos reducciones, la sanción quedaría establecida en **60.000,00 euros** y su pago implicaría la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la notificación del citado acuerdo de inicio, **AIRE NETWORKS** ha procedido al reconocimiento de la responsabilidad y al pago voluntario de la sanción, acogándose a las dos reducciones previstas. De conformidad con el apartado 3 del artículo 85 LPACAP, la efectividad de las citadas reducciones estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del Tribunal Supremo en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones, la Presidencia de la Agencia Española de Protección de Datos **RESUELVE**:

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva del acuerdo de inicio transcrito en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total **100.000,00 euros**.

Tras haber procedido **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.** al pronto pago y reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 40% del total mencionado, lo cual supone la cantidad definitiva de **60.000,00 euros**.

La efectividad de las citadas reducciones está condicionada, en todo caso, al desistimiento o renuncia de cualquier acción o recurso en vía administrativa.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202310943**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: NOTIFICAR la presente resolución a **AIRE NETWORKS DEL MEDITERRÁNEO, S.L.**

CUARTO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario y reconocimiento de la responsabilidad al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, la presente resolución será firme en vía administrativa y plenamente ejecutiva a partir de su notificación.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa según lo preceptuado por el art. 114.1.c) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, los interesados podrán interponer recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-Administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

No obstante, conforme a lo previsto en el artículo 90.3.a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeaeps.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

936-200325

Lorenzo Cotino Hueso
Presidente de la Agencia Española de Protección de Datos